

個人情報×生成AI 実務ガイド

個人情報を扱う組織のための、判定フローと要配慮個人情報を扱う場合の技術構成 — 2026年9月時点の
公式一次情報だけで組み立て直す実務資料

最終確認 2026-09-22

一次情報ベース・出典14件

対象:個人情報を扱う全ての組織

最新版はこちら ↗

この資料でわかること

- 個人情報保護法が課す「2つの独立した義務」の違いと、それぞれの解決手段
- AIに入れてよい情報のレベルを、3つの質問だけで判定する方法
- 「ISMAP登録済み」という言葉が実際に意味すること・意味しないこと
- 越境移転規制（法28条）が生成AI利用に与える具体的な影響
- 要配慮個人情報を実名で扱うための、現実的な技術構成とコストの根拠

対象読者：個人情報・要配慮個人情報を扱いながら生成AIの活用を検討する、福祉施設・自治体・NPO・中小企業等の意思決定者および情報システム担当者。特定のベンダーやサービスの宣伝を目的としたものではありません。本文中の [n] は巻末「出典一覧」の番号に対応します。

目次

00	はじめに	p.3
	なぜこの整理が必要か	
01	大原則：個人情報保護法の「2つの壁」	p.4
	安全管理措置と、適法な取得・利用は独立している	
02	判定フロー：3つの質問	p.5
	個人特定情報／要配慮個人情報／処理体制の3段階判定	
03	越境移転規制（法28条）	p.7
	「日本国内処理」が必要になる法的根拠	
04	ISMAP登録の構造と落とし穴	p.8
	「登録済み」が自動的に意味しないもの	
05	実名データの3段階（Tier A / B / C）	p.9
	用途別に必要な技術要件を切り分ける	
06	よくある間違いと正しい対応	p.10
	NG例・OK例で確認する、現場で起きがちなもの	
07	Tier Cの技術構成とその根拠	p.12
	要配慮個人情報のための現実的なアーキテクチャ	
08	技術を固めても残る法務対応	p.14
	積み上げれば完了する軸と、終わりのない軸の違い	
09	まとめ：今日からできること	p.15
	できること・まだできないこと・準備すべきこと	
—	出典一覧	p.16
	本文中の番号に対応する公式情報源、14件	

各社の規約・料金・対応リージョンは頻繁に更新されます。意思決定の直前には、出典一覧のリンクから必ず最新情報を確認してください。

「ISMAPを満たしているから安全」——それ、半分しか合っていません

個人情報を扱う組織が生成AIの導入を検討する際、「ISMAPを満たしているので個人情報を安全に取り扱える」という説明に出会うことがあります。では実際には、どのレベルの情報まで入力してよいのでしょうか。

この質問の背景には、よくある誤解があります。「ISMAP登録済み」「学習に使われない」といった言葉は、**安全に“守る”仕組み**があるかどうかの話でしかありません。そもそも**その情報を扱ってよいか**は、まったく別の判断軸です。

この資料の狙い

この資料は、上記のような現場の疑問に対して、2026年9月時点で確認できる公式一次情報だけを根拠に、次の2つを整理し直したものです。

1. **判定フロー** — 手元のデータをAIに入れてよいかを、3つの質問で判定する方法（第2章）
2. **技術構成** — 要配慮個人情報を実名で扱わざるを得ない場合に、現実的に組める技術構成とその根拠（第7章）

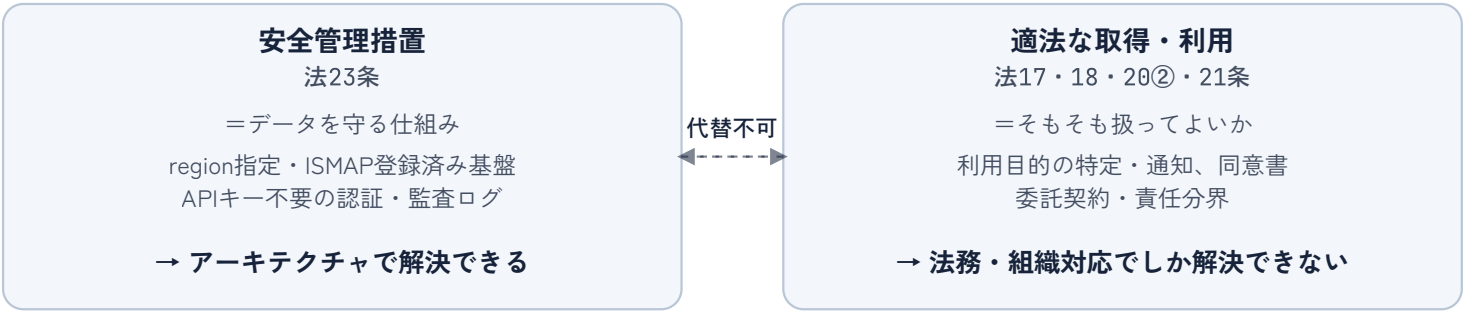
読み方

本文中の **[n]** は、巻末「出典一覧」（p.16）の番号に対応します。日本語OCRの精度比較のみ、社内の非公開実機検証に基づく知見のため、**[†]** で示し公開リンクなしと明記しています。専門的な法律用語には、初出時に簡単な説明を添えています。

なお本資料は、特定の福祉施設・自治体・団体名や個別の相談内容には触れていません。個人情報を扱いながら生成AIの活用を検討する組織全般に共通する論点として整理しています。

「安全に守る」義務と「そもそも使ってよいか」の義務は、独立している

個人情報保護法は、大きく分けて2つの義務を組織に課しています。この2つは監督する条文も、満たす手段もまったく別物であり、片方を満たしても、もう片方の違反は消えません。



「アーキテクチャを固めたから要配慮個人情報も安全」は成立しない

図1. 個人情報保護法が課す2つの独立した義務。片方（技術）を満たしても他方（法務）の代わりにはならない。

関係する条文の早見表

条文	内容	区分
17条	利用目的の特定	法務
18条	利用目的による制限（目的外利用の禁止）	法務
20条2項	要配慮個人情報の取得には原則本人同意が必要	法務
21条	取得に際しての利用目的の通知・公表	法務
23条	安全管理措置（データを守る技術・体制）	技術
25条	委託先の監督	技術+法務
27条	第三者提供の制限（原則）	法務
28条	外国にある第三者への提供の制限（越境移転規制）	技術+法務

条文番号は現行の個人情報保護法（令和2年改正後）に基づく [\[3\]](#)。

3つの質問で、入れているレベルが決まる

「結局、どのレベルから個人情報を入れてよいのか」という疑問に、3段階の質問で答えます。「はい」を辿るほど要件は厳しくなり、**要配慮個人情報**は必ず最後の質問まで確認する必要があります。

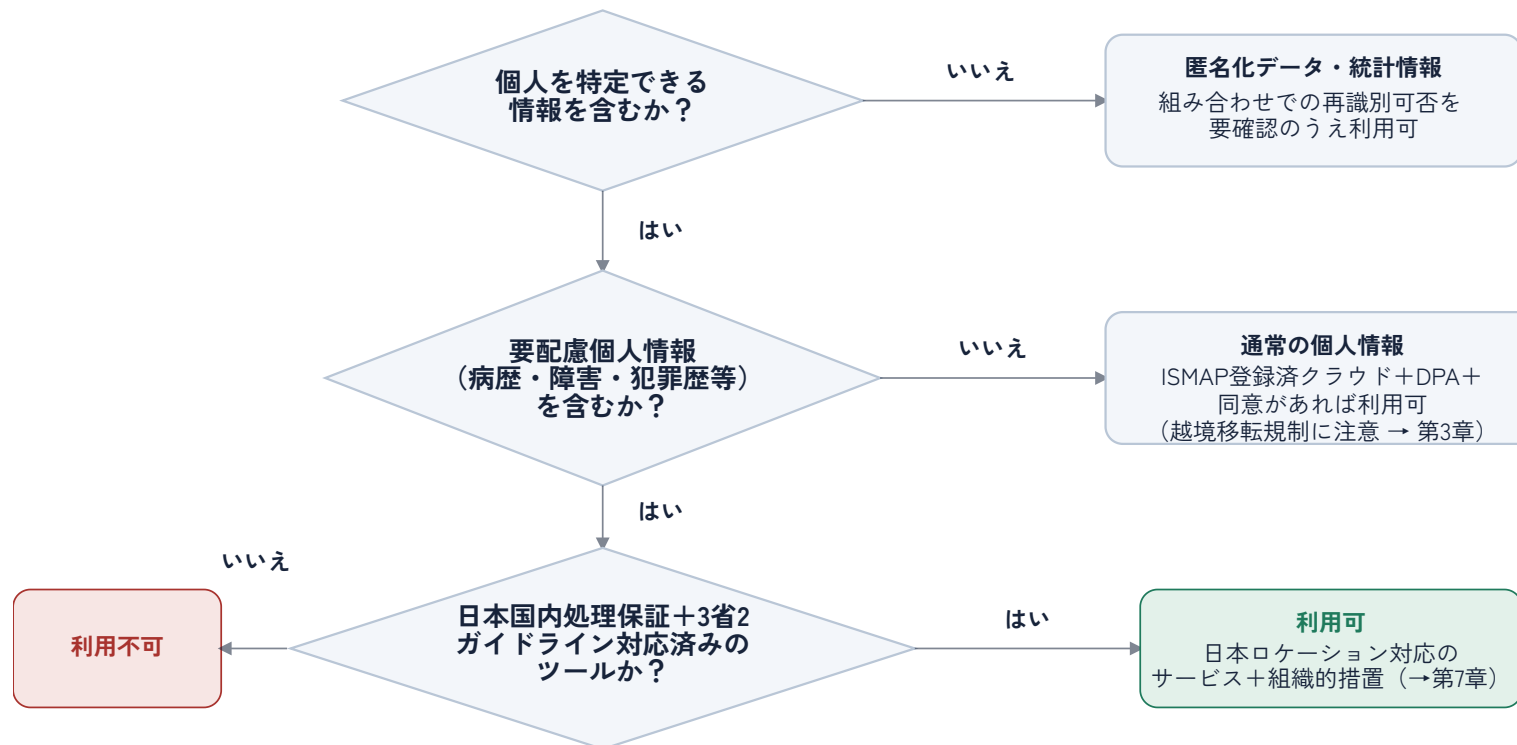


図2. 個人情報のレベル別判定フロー。DPA＝データ処理契約（第8章で詳述）。3省2ガイドライン＝厚生労働省・総務省・経済産業省が定める医療情報の安全管理ガイドライン群。

具体例早見表

実務でよく出てくる入力内容を、上記フローに沿って分類すると次のようになります。

入力しようとしている内容の例	分類	目安
一般的な案内文・チラシのひな形（個人名なし）	匿名化情報	問題なし
研修資料・マニュアルの下書き	匿名化情報	問題なし
施設名・職員の氏名	通常の個人情報	条件付きで可
利用者の氏名・住所・連絡先のみ	通常の個人情報	条件付きで可
利用者の病歴・障害の状況	要配慮個人情報	非推奨
逮捕歴・犯罪の経歴	要配慮個人情報	非推奨
ケース記録全般（病歴・生活歴等を含む）	要配慮個人情報を含む可能性大	非推奨（個別確認）

「匿名化済みだから安全」の落とし穴

氏名等の直接的な識別子を除いても、**年代＋地域＋利用施設のように複数の属性を組み合わせると、本人が再識別できてしまう場合があります。**

「個人を特定できる情報を含まないか」の判定は、単一の項目だけでなく組み合わせの観点でも行う必要があります。判断に迷う場合は、常に「入れない」を選ぶことが原則です。

生活保護受給歴の扱いについての注記

「生活保護の受給歴」そのものは、個人情報保護法が列举する要配慮個人情報の定義に直接該当するとは限りません^[3]。しかし、ケース記録には病歴・障害等の要配慮個人情報と併記されることが多く、実務上は要配慮情報に準じた慎重な取り扱いが妥当です。個別の該当性判断は専門家にご確認ください。

「日本国内処理」が必要になる理由 — 個人情報保護法28条

ISMAP登録の有無（法23条）とは別に、もう一つ重要な論点があります。外国にある第三者への提供の制限（法28条）です。令和2年改正により、この規定は旧24条から現在の28条へ条番号が変更されています^[3]。

多くの生成AIサービスは、データの処理地を「グローバル」「米国」「ヨーロッパ」といった広域リージョンからしか選べず、日本国内に固定できません。法28条は、次のいずれかに該当しない限り、**あらかじめ本人の同意を得ることを求めています**。

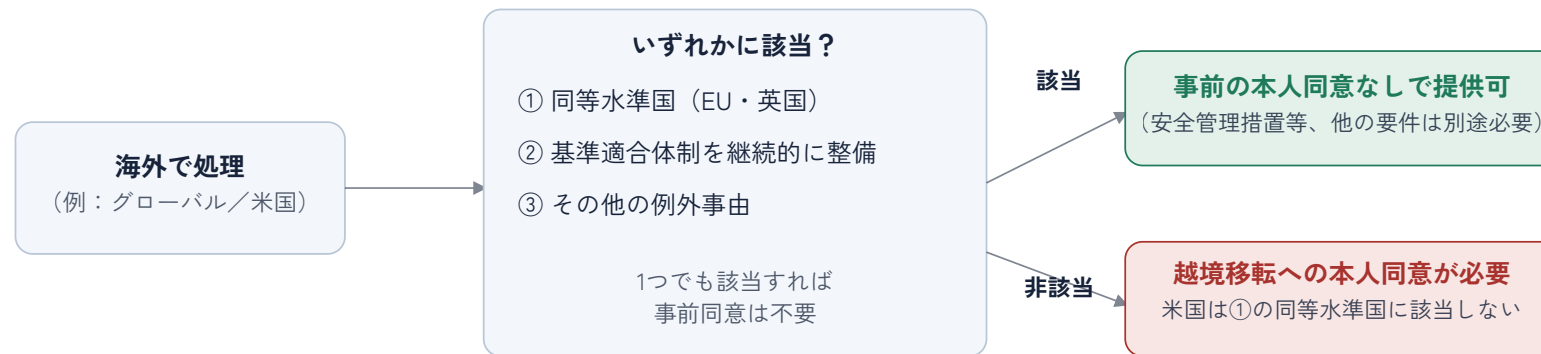


図3. 個人情報保護法28条の判定構造^[1]。ISMAP登録（法23条）はこの論点をクリアする根拠にはならない。

個人情報保護委員会は、EU（欧州連合）と英国を「個人の権利利益を保護する上で我が国と同等の水準にあると認められる国」として指定しています^{[1][2]}。米国はこの指定対象に含まれないため、米国リージョンでの処理を伴うサービスでは、②の基準適合体制がない限り、越境移転への本人同意が実務上ほぼ必須になります。

「基盤の登録」は「上位サービス」に自動継承されない

ISMAP（政府情報システムのためのセキュリティ評価制度）は、国家サイバー統括室・デジタル庁・総務省・経済産業省が所管し、IPA（情報処理推進機構）が運用支援機関として実務を担う、令和2年6月開始の制度です。評価済のクラウドサービスは、ISMAPクラウドサービスリストに登録番号とともに掲載されます^[5]。

ここで見落とされがちなのが、「登録済みの基盤の上に構築されたサービスが、自動的に同じ扱いになるとは限らない」という原則です。ISMAP公式FAQは次のように明記しています。

「ISMAP登録済みのIaaS/PaaS上に構築したSaaSは、SaaS自体が別途登録しない限り同等とみなせない」^[4]

Google（3層・別々の登録）

Google Cloud
C21-0004-2

Workspace
C21-0005-2

Gemini Enterprise
C26-0114-2

AWS（単一登録）

AWS（Bedrock明記）

C21-0008-2

除外はBedrock Marketplaceのみ

基盤の登録は自動継承されない（要個別確認）

個々の生成AIモデル（Gemini・Nova・Claude等）自体は、基盤がISMAP登録範囲に含まれていれば別途登録不要——これはISMAP運営主体自身の公式見解。

図4. Google関連は3つの独立した登録番号に分かれる一方、AWSはBedrockを含む単一登録^{[5][7][8]}。個々のモデルは基盤の登録範囲内であれば別途登録不要という点はISMAP運営主体の公式見解^[6]。

実際、Gemini Enterprise（C26-0114-2）はVertex AI Platform（C21-0004-2に含まれる）上に構築されているにもかかわらず、2026年4月28日に別途本登録が必要でした^[7]。「基盤がISMAPだから上位のSaaS機能も自動的にISMAP」という推論は成立しません。

Tier A / B / C — 右に行くほど要件が跳ね上がる

実名データを扱う場合に必要な技術要件は、データの機微度によって3段階に分かれます。

TIER	代表的な用途	必要な技術要件
A 匿名化	個人が特定されない一般的な文章生成・要約・案内文作成	特別な要件なし。一般的なクラウドAIで可
B 通常の個人情報 (実名)	施設名・担当者名等を含む議事録・案内文	ISMAP登録済みクラウド+DPA締結+同意取得。日本リージョン限定は必須ではないが推奨（越境移転規制に注意 → 第3章）
C 要配慮個人情報 (実名)	ケースワーク記録の要約、相談面談音声の議事録、書類のAI OCR化	Bの要件に加え、データの保存+AI処理が日本国内に完全に閉じること、APIキーレス認証、3省2ガイドライン相当の組織的措置

Tier Bで利用可能な選択肢／避けるべき選択肢

- **Gemini in Workspace** — Google Workspace自体がISMAP登録済みで、Geminiアプリ・Gemini in Workspaceは対象範囲に明記されている^{[5][14]}。日本限定の選択肢はないが、Tier Bでは許容範囲
- **Gemini Enterprise** — Workspaceとは別契約。日本ロケーション指定が可能、より安全に倒せる選択肢
- **Vertex AI（Gemini Enterprise Agent Platform）のAPI** — ISMAP登録済み。リージョン問わずTier Bなら利用可

✗ Google AI Studioの素のAPIキーはNG。 ISMAP対象外の別製品で、データが世界中どこでも保存されうる^[13]

補足：Gemini Enterpriseの無料トライアルに注意

Gemini EnterpriseはBusiness版であれば、IT部門のセットアップや営業への問い合わせなしで30日間の無料トライアルをセルフサーブで開始できます^[12]。したがって「管理コンソールでトグルがオンになっている」＝「正式に契約済み」とは限らず、実際の契約状況は別途確認が必要です。

同じ「Gemini in Workspace」でも、使い方で明暗が分かれる

ここまでの判定フローとTier分類を理解していても、現場では「良かれと思って」誤った使い方をしてしまうことがあります。最も多いのが、次のケースです。

❌ NG例：相談記録をそのまま要約させている

職員が、利用者の氏名・病歴・生活状況を含む相談記録を、法人契約のGemini in Workspaceに貼り付けて「要約して」と依頼している。ISMAP登録済みだから安全だと考えている。

実態：これは **Tier C** のデータを **Tier B** の環境で処理している状態。ISMAP登録（法23条）は満たしていても、①処理地を日本国内に固定できない（法28条・越境移転）、②要配慮個人情報の取得同意が想定範囲を超えている可能性（法20条2項）^[3]という2つの問題が残ったままです。

✅ OK例：用途に応じて仕分けている

同じ相談記録でも、案内文の下書き程度なら氏名等を「A様」に置き換えてから、同じGemini in Workspaceで作成。病歴・生活歴を含む要約作業は、正式なTier C構成（第7章）が整うまで人手で行うと決めている。

ポイント：ツールを変えなくても、「何を入れるか」を仕分けるだけでリスクは大きく下がります。困ったら、まず匿名化してからが原則です。

なぜ組織は気づきにくいのか

「ISMAP登録済み」「大手ベンダーの法人契約」という言葉が、安心感を生みやすいためです。しかし第1章・第4章で見たとおり、ISMAP登録（安全管理措置）と、越境移転規制・同意取得（適法な取得・利用）は**独立した別の壁**です。片方が万全でも、もう片方はクリアできていない、という状態が最も見落とされやすいパターンです。

見分け方：3秒でできるセルフチェック

入力しようとしている文章に、①氏名・住所等の直接的な識別子、②病歴・障害・犯罪歴等の要配慮情報、③年代＋地域＋利用施設のような組み合わせ、のいずれかが残っていないか。1つでも該当するなら、それは **Tier C** 相当の可能性が高く、通常のGemini in Workspaceでの処理は避けるべきタイミングです（判定フローは第2章）。

見落としやすい、もう2つのケース

ケース2：個人のGoogleアカウント・個人契約のAIを業務で使う

NG：職員が自分のスマホの個人Googleアカウント、または個人契約のChatGPT・Geminiアプリで、隙間時間に相談記録の下書きを作っている。

問題：個人プランは既定で学習対象になりうる設定が多く、監査ログもない。退職時のデータ持ち出しを止められず、そもそも法人としての委託契約（法25条）が存在しません。

OK：法人契約（Gemini in Workspace等）に一本化し、内規で個人アカウントの業務利用を明示的に禁止している。

ポイント：「便利だから個人アカウントで」を許容した瞬間、監査ログ・DPA・委託先監督のすべてが空白になります。

ケース3：Google AI StudioのAPIキーで自作した社内ツール

NG：情報システム担当者がGoogle AI Studioで発行した無料のAPIキーを使い、社内向けの文書要約ツールを自作。便利なので現場が要配慮個人情報を含む文書もどんどん投入している。

問題：このAPIキーはISMAP対象外の別製品で、データが世界中どこでも保存されうる仕様です^[13]。「自分たちで作ったから安心」という思い込みが、実は最も無防備な経路になっている典型例です。

OK：同じ機能をVertex AI（Gemini Enterprise Agent Platform）のAPI経由で作直す。ISMAP登録済みの環境の範囲内に収まります。

ポイント：「内製・自作だから安全」とは限りません。むしろ管理者の目が届きにくく、リスクが放置されやすい経路です。

この3つのケースはいずれも、①扱っているデータの機微度と、②実際に使っているツールの体制がずれていることが原因です。ずれに気づいたら、次章（Tier Cの技術構成）で扱う正式な移行を検討してください。

要配慮個人情報を実名で扱う場合の、現実的な最適構成

2026年9月時点で最も現実的なのは、既存のGoogle Cloudインフラは維持しつつ、テキスト生成・要約・音声文字起こしはAWS Bedrockに任せるハイブリッド構成です。ただしAI OCRだけは例外で、自前ホスティングへ切り出します（理由は次頁）。

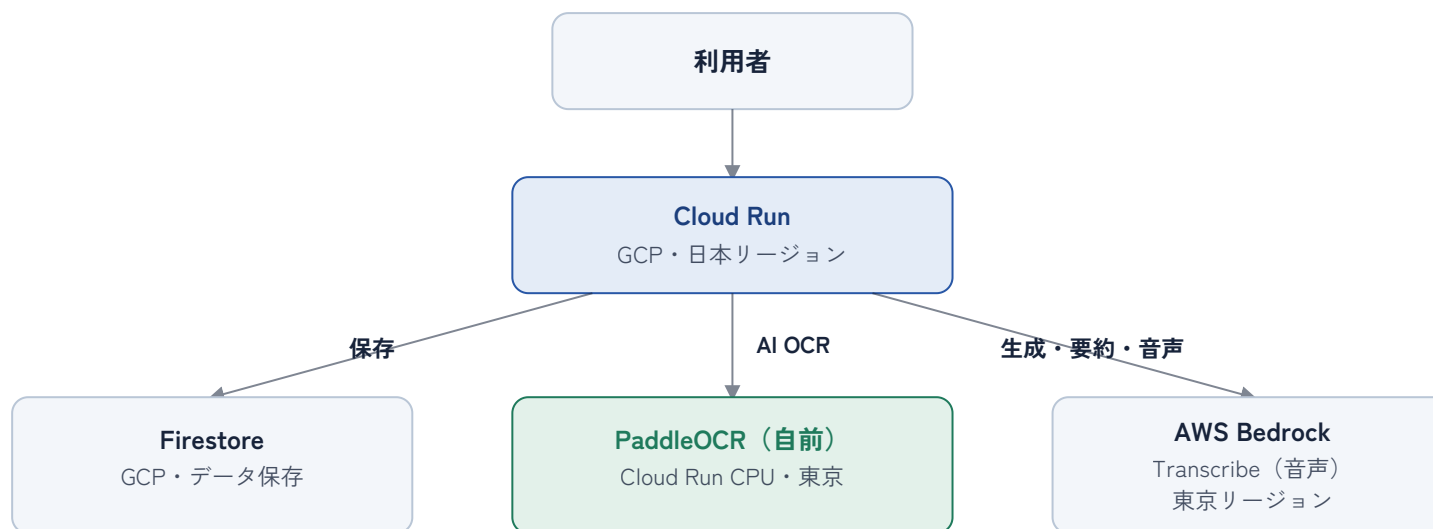


図5. データの保存・AI処理は常に日本国内に閉じる。AI OCRだけを自前ホスティングへ、それ以外の生成AI処理はAWS Bedrockへ。クラウド間はキーレス認証。

技術を固めても残る法務対応

- 利用者への同意取得・プライバシーポリシー改定
- クラウド事業者とのDPA（データ処理契約）締結
- 委託先とのNDA（秘密保持契約）・業務委託契約
- 3省2ガイドライン相当の組織的措置

この構成が変わりうる条件

各社の料金・対応リージョンは半年単位で変わります。契約更新のタイミングで、出典一覧のリンクから再確認することを推奨します。

コストと精度、両方の一次情報が同じ結論を指す

コスト構造

Gemini 3.5 Flashを日本リージョン（asia-northeast1）で使う場合、標準従量課金（Standard PayGo）は非対応です^[9]。利用できるのは単一ゾーンのProvisioned Throughputのみで、購入には「Google Cloudアカウント担当者への問い合わせ」が必須の個別契約になります^[10]。公式料金ページの試算例では、月額 **\$2,700 × GSU数** という水準が示されています^[11]。小規模な組織には現実的ではありません。対して、AWS Bedrock（Nova系・Claude系）は固定費なしの従量課金のまま、東京リージョン内で完結します^[8]。

日本語OCR精度の実機比較

実際の日本語書類（旧字体異体字・類似漢字・事業所名の紛らわしいペア等）を使った実機検証では、AWS Bedrock（Claude／Nova系）は特定の漢字を再現性ある形で誤読することが確認されました。自前ホスティングのPaddleOCRは、Gemini系とほぼ同水準の精度を達成しています^[†]。

モデル	正解率(96判定中)	備考
Gemini 2.5 Flash	100%	2026年10月20日一般提供終了・2027年3月31日完全廃止のため除外
Gemini 3.5 Flash	99% (95/96)	
PaddleOCR（自前ホスティング）	98% (94/96)	Apache 2.0、東京リージョンCloud Run運用可
AWS Bedrock Claude Sonnet 4.5	約87.5%	
AWS Bedrock Claude Haiku 4.5	62.5～75%	enum制約等の改善後の数値

評価軸：OCRテキストを既知のマスターリストにfuzzy matchで解決できるかという、実運用に即した基準^[†]。いずれのモデルも「誤って別の実在レコードに確定する」危険な誤りは検証全体を通じて0件でした。

4つの軸——積み上げれば完了するもの、しないもの

アーキテクチャ（②）・NDA・DPA（③）・同意書（①）・ログ整備（④）を積み上げれば自動的に「合格」になる、というチェックリストではありません。要配慮個人情報情報を扱う体制は、性質の異なる次の4つの軸に分けて確認する必要があります。

#	軸	該当条文	何を見れば確認できるか
①	適法な取得・利用	17・18・20②・21条	運営者の契約書・プライバシーポリシー実物のみ 。AI・コードからは確認不可能
②	安全管理措置	23条	アーキテクチャ調査で確認可能
③	委託先の監督	25条	NDA・DPA等の契約書の有無に加え、監督の実施記録（評価・監査履歴）まで必要
④	追跡可能性	23条（運用面）	ログ基盤の設定に加え、実際の保持運用の確認まで必要

①～④を全部満たしても、「もう終わり」にはならない

②③④は「**運営者⇄ベンダー**」間の**技術・契約対応**で、委託先とのNDA・DPA締結（③）、アーキテクチャ整備（②）、ログ基盤の構築（④）という形で一度体制を整えれば、基本的に完了したと言えます。しかし①だけは「**運営者⇄本人（サービス利用者）**」間の**同意**で、ベンダーとのNDA・DPA（③）をどれだけ強化しても①の代わりにはなりません。「同意書のひな形を用意した」とことと「既存の利用者全員から実際に同意を取得済みである」ことはまったく別の問題です。**つまり、新しい利用者と契約するたびに、その都度本人から同意書を取得する必要がある**ということであり、一度整えれば終わる話ではありません。

マルチベンダー構成はコンプライアンス上むしろ改善しうる

「単一の生成AIベンダーに全タスクを寄せる」構成から、「最も機微データ密度が高い処理（例：生文書画像のOCR）だけを自前ホスティングに切り出し、それ以外を用途別に別ベンダーへ振り分ける」構成に変えると、生の機微データに触れる第三者事業者の数はむしろ減る方向に働きます。ベンダーを増やす＝リスク増、という直感はずしも正しくありません。ただし、既存の同意書・プライバシーポリシーが新しい委託先を含む処理を許容する記載になっているかは、都度レビューが必要です。

今日からできること、正直まだできないこと

✔ 今日からできる

個人が特定されない一般的な文章生成・要約・案内文は、今使っているツールのままで問題ありません。氏名・住所・生年月日等を仮名（A様、B様等）に置き換えれば、活用の幅はかなり広がります。「困ったら、まず匿名化してから」を職場のルールにするだけで効果があります。

✖ 正直、まだできない

利用者の実名と病歴・生活歴等を**そのまま**一般的なAIツールに入力すること。「今の契約・今のツールのまま」でこれを安全にクリアする方法は、2026年9月時点では存在しません。期待を持たせすぎないよう、はっきりお伝えします。

組織として計画的に準備すべきこと

要配慮個人情報を実名で扱えるようにするには、個人のスマホ設定のように「その場で解決すること」ではなく、**システム構築と契約整理を伴う一定規模のプロジェクト**として進める必要があります。

- Tier C対応の技術基盤の構築（Gemini Enterprise日本ロケーション、またはAWS Bedrock等を用いたハイブリッド構成）
- 費用感の見積もりと予算確保（固定費が発生する構成もあるため事前の比較検討が必要）
- ISMAP登録範囲の個別確認（前章②）、クラウド事業者とのDPA締結（前章③）
- 3省2ガイドライン相当の組織的措置の整備
- 利用者への同意取得（前章①）・プライバシーポリシーの改定

これらは技術・法務の両面にまたがる専門的な整理が必要で、片手間で進めるのは現実的ではありません。まずは「誰が意思決定者で、いつまでにどの範囲を実現したいか」を組織内で確認するところから始めることをおすすめします。

すべて公式ドキュメント・公式ポータルで直接確認

本文中の番号 [n] に対応します。いずれも2026年9月時点で内容を直接確認しています。

法令・個人情報保護

1. 個人情報保護法ガイドライン（外国にある第三者への提供編） | 個人情報保護委員会 — ppc.go.jp/personalinfo/legal/guidelines_offshore
2. 個人情報の保護に関する法律第28条に基づくEU及び英国の指定の見直しに関する報告書 | 個人情報保護委員会事務局 — ppc.go.jp/files/pdf/20230322_review_report.pdf
3. 個人情報保護法ガイドライン（通則編） | 個人情報保護委員会 — ppc.go.jp/personalinfo/legal/guidelines_tsusoku

ISMAP

4. ISMAPポータル公式KB0010826（IaaS/PaaS上のSaaSは別途登録が必要という原則） — [ismap.go.jp（KB0010826）](https://ismap.go.jp/KB0010826)
5. ISMAPクラウドサービスリスト | ISMAPポータル公式 — ismap.go.jp/cloud_service_list
6. ISMAPポータル公式KB0011070（生成AIサービスに関する留意点について） — [ismap.go.jp（KB0011070）](https://ismap.go.jp/KB0011070)
7. Gemini Enterprise・NotebookLM Enterprise の ISMAP登録を完了 | Google Cloud公式ブログ — cloud.google.com/blog/ja/...ismap-registration

クラウド料金・データ所在地

8. Amazon Bedrock は ISMAP の言明対象であることについての考え方 | AWS公式ブログ — aws.amazon.com/jp/blogs/news/amazon-bedrock-ismap
9. Gemini 3.5 Flash モデルページ | Google Cloud公式 — docs.cloud.google.com/.../3-5-flash
10. プロビジョンドスループットを購入する | Google Cloud公式 — docs.cloud.google.com/.../purchase-provisioned-throughput
11. Agent Platform の料金 | Google Cloud公式 — cloud.google.com/.../generative-ai/pricing
12. Gemini Enterprise app FAQ（30日間無料トライアル） | Google Cloud公式 — cloud.google.com/gemini-enterprise/faq
13. Gemini API 利用規約 | Google AI for Developers公式 — ai.google.dev/gemini-api/terms
14. Google Workspace 「生成AIに関する情報」 開示書（Google LLC提出、ISMAPポータル） — [ismap.go.jp（開示書PDF）](https://ismap.go.jp/（開示書PDF）)

非公開の社内検証

【†】日本語OCR精度の比較（p.13）は、実際の業務文書を用いた社内実機検証に基づく知見です。公開されている一次情報へのリンクはありません。数値の再現性は検証環境に依存します。

本資料は2026年9月22日時点で確認できた公式一次情報に基づく技術的整理です。各社の規約・料金・対応リージョンは頻繁に更新されるため、意思決定の直前には必ず公式ページで再確認してください。法的な最終判断は専門家にご確認ください。特定のベンダー・サービスの宣伝を意図したものではありません。